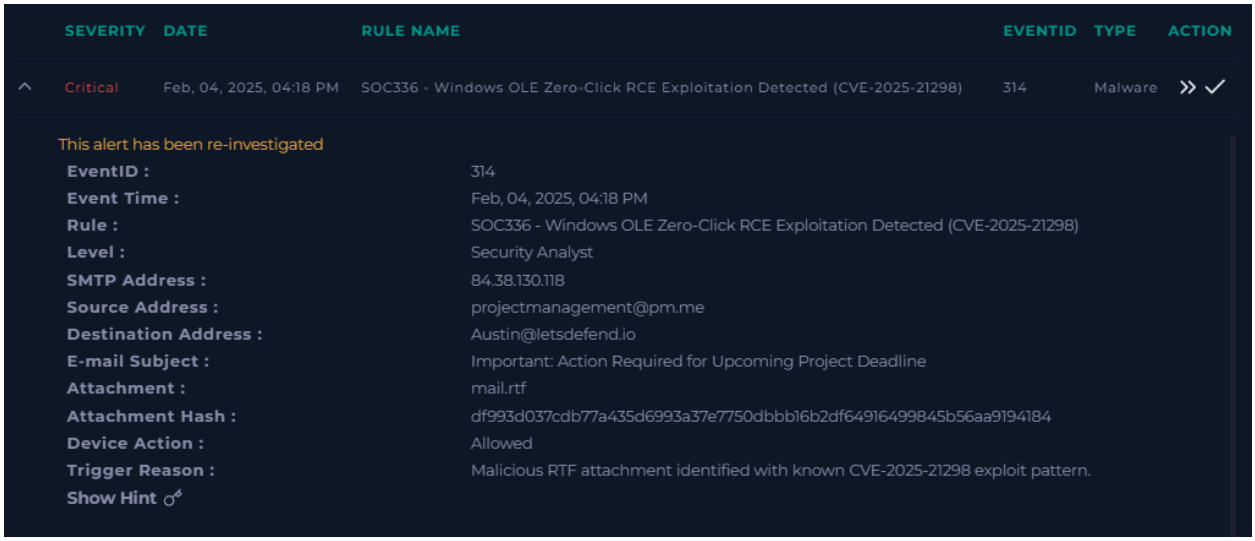
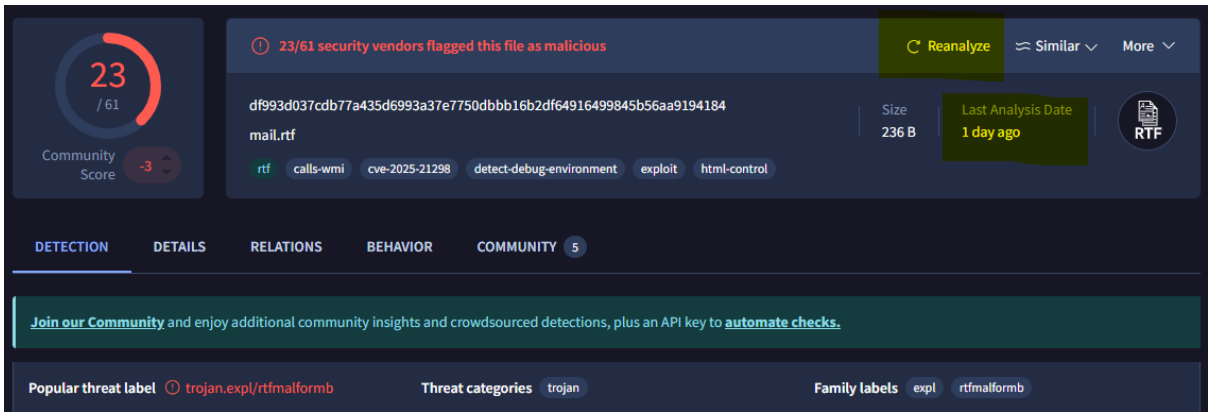
SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)



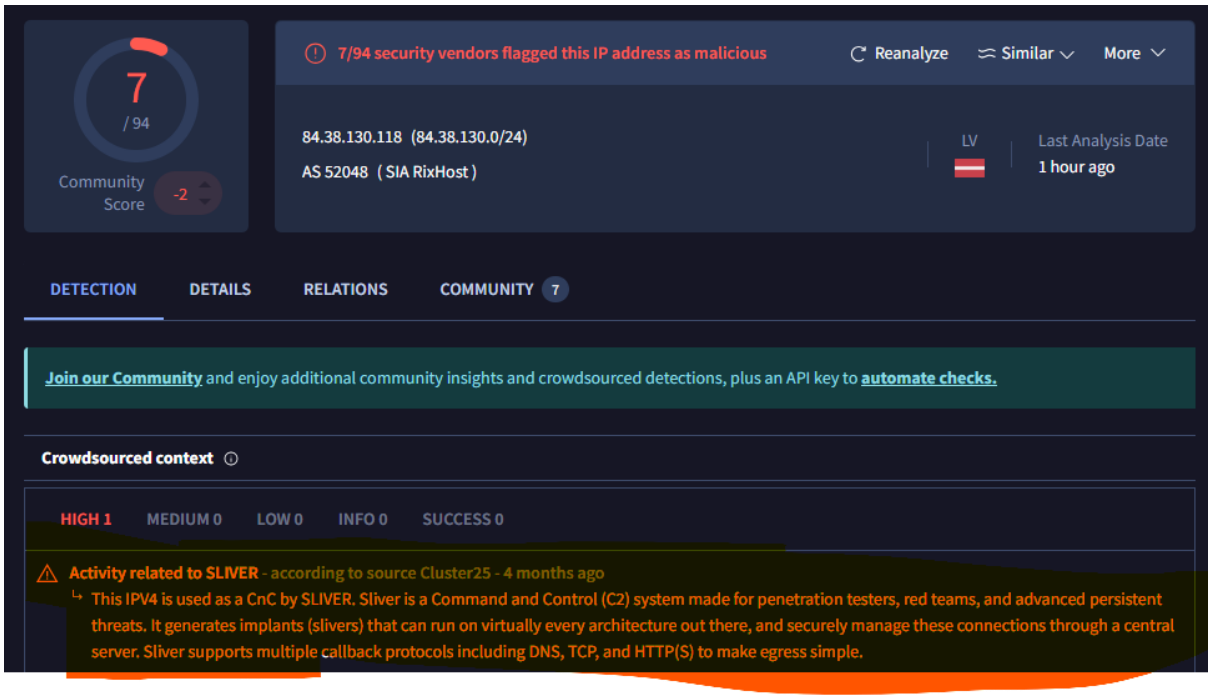
Primeros pasos

Lo primero que hacemos es revisar el hash del archivo comprimido usando Virus total.



Como recomendación personal recomiendo siempre fijarse en la ultima vez que fue analizarlo y si ha pasado un tiempo considerable presionar “Reanalizar”.

Lo segundo que revisamos es la dirección SMTP.



Según los resultados de Virus total vemos que coincide con la alerta activa con lo cual podemos ir determinando que se trata de un verdadero positivo relacionado a un intento de explotación del **CVE-2025-21298**.

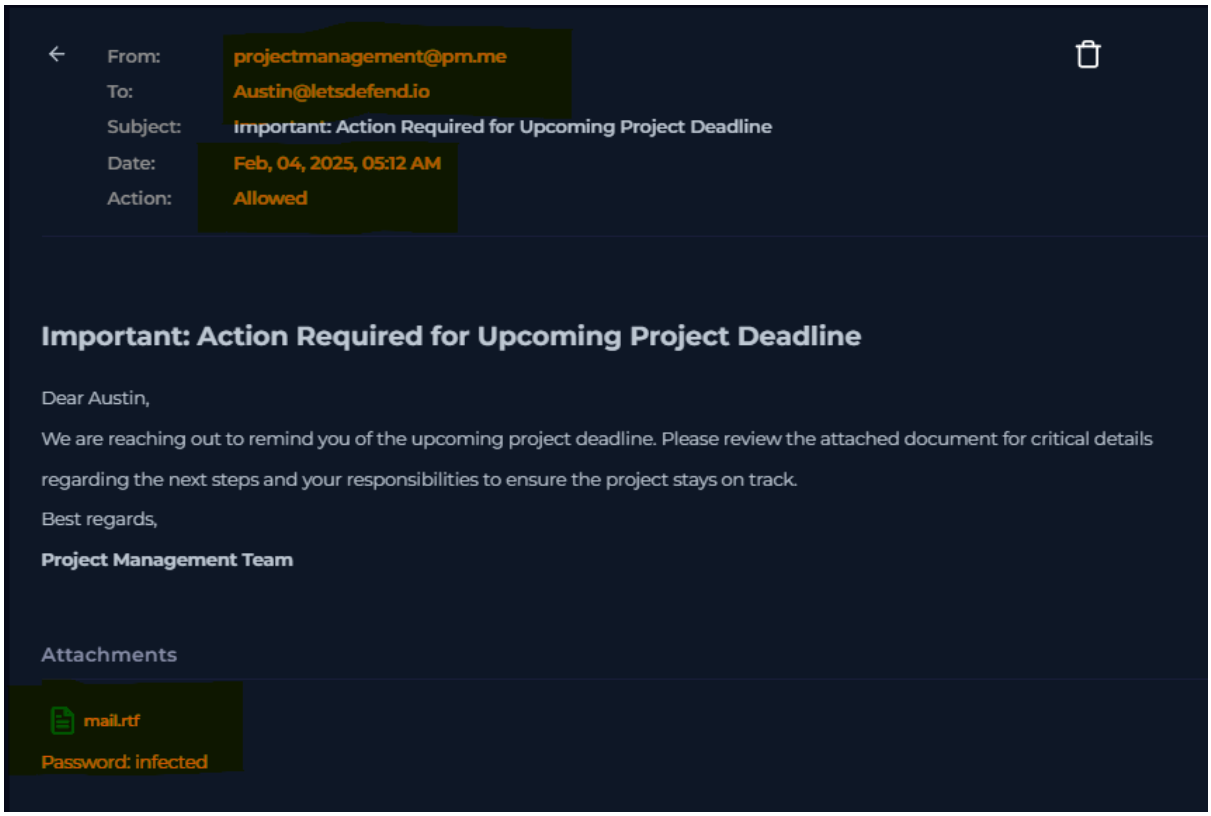
CVE-2025-21298

Es una vulnerabilidad crítica en Windows que permite la ejecución remota de código (RCE) a través de una tecnología llamada OLE (Object Linking and Embedding). OLE es una tecnología antigua de Microsoft que permite incrustar o vincular objetos (como hojas de Excel o gráficos de Word) entre diferentes aplicaciones de Windows.

En este caso un atacante crea un archivo manipulado llamado **mail.rtf** el cual contiene OLE malicioso, cuando el usuario abre el archivo se ejecuta código malicioso sin que se de cuenta.

Investigación del correo

Vamos al apartado **Email Security** y buscamos los correos de **Austin.**



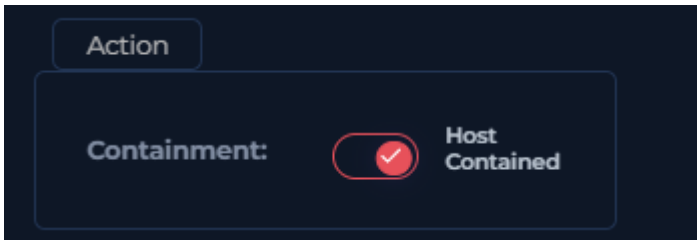
Hasta este momento tenemos varios datos: Quien envió el correo, la dirección SMTP del correo, si el correo paso los filtros de seguridad, también si el usuario lo recibió y el archivo adjunto llamado “mail.rtf”.

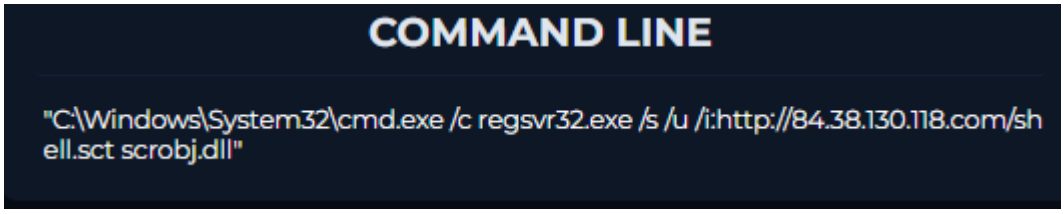
Con estos datos confirmamos que el usuario recibió el correo, ahora queremos saber si descargo, el archivo y lo ejecuto.

Revisión del dispositivo

Vamos a “EndPoint Security” y buscamos el equipo de **Austin.**

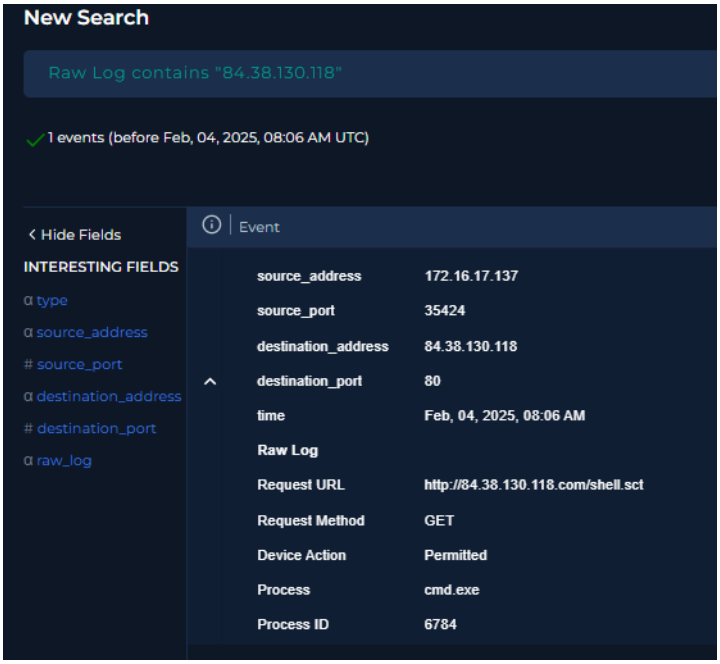
Por experiencia inicio buscando el historial de comandos ejecutados en el equipo, aquí encuentro algo sospechoso que me confirma que código malicioso se ejecuto en el dispositivo, con lo cual procedemos a aislar el mismo.





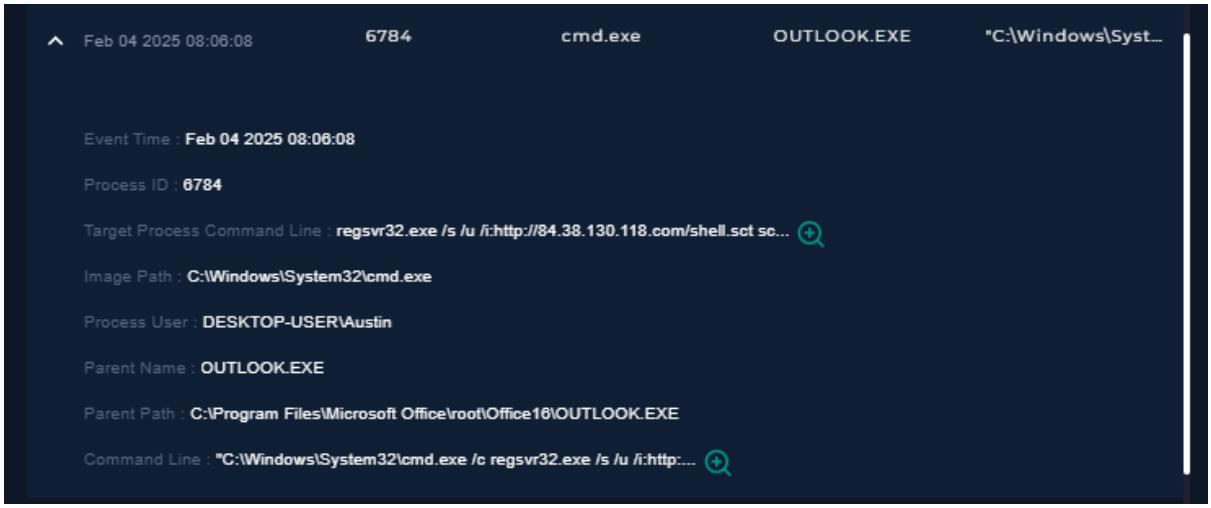
De forma básica, el comando usa cmd.exe para ejecutar regsvr32, una herramienta de Windows que normalmente sirve para registrar librerías DLL. En este caso, se usa de forma maliciosa para descargar y ejecutar un archivo de script (shell.sct) desde la dirección que se ve en el comando. Ese script se ejecuta a través de una librería legítima de Windows (scrobj.dll), permitiendo que el atacante ejecute código en el equipo sin que el usuario lo note.

Ahora investigamos en la ventana “Log Management” para saber si la descarga fue exitosa.



Vemos que si fue exitosa la descarga y obtenemos el ID del proceso que realiza la conexión.

Vamos a investigar los procesos en el equipo.



Vemos que el usuario desde la aplicación Outlook.exe, abrió el archivo adjunto y ejecuta el malicioso.

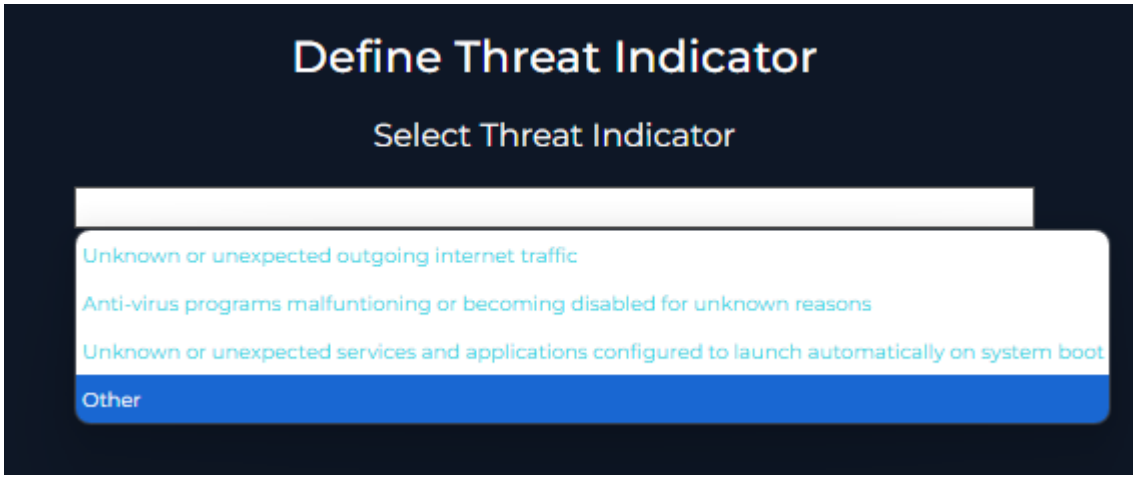
También vemos el ID del proceso cmd.exe



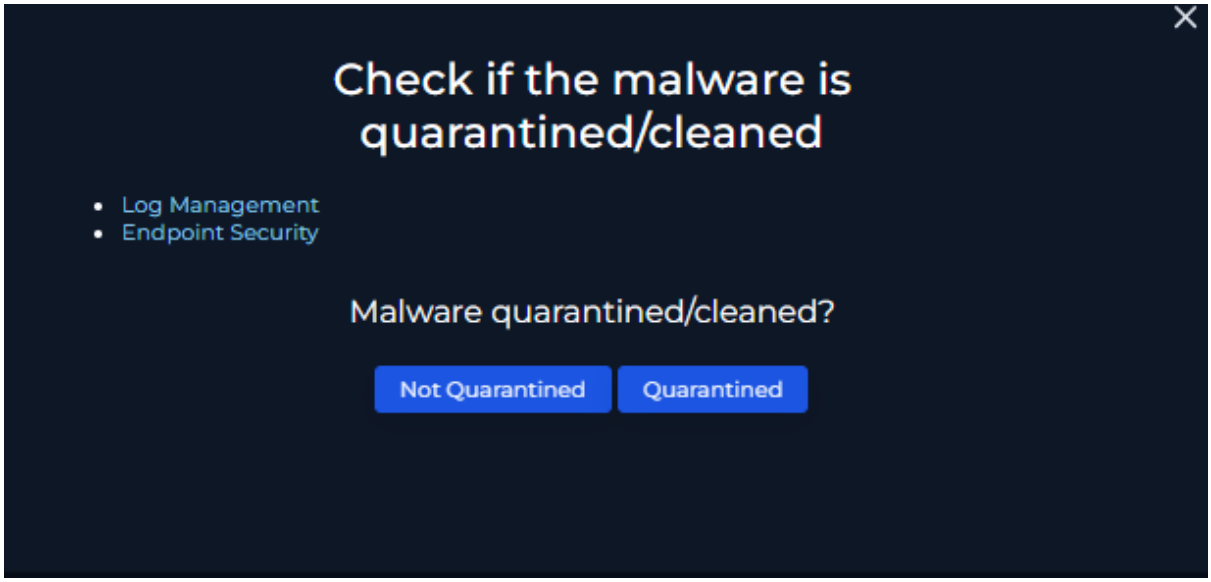
Esta alerta no cubre la investigación mas profunda del equipo o de los archivos descargados entonces hasta aquí tendríamos suficientes datos para escalar el caso a un analista de nivel 2 para continuar con las investigaciones y respuesta ante incidentes.

Realizamos el playbook

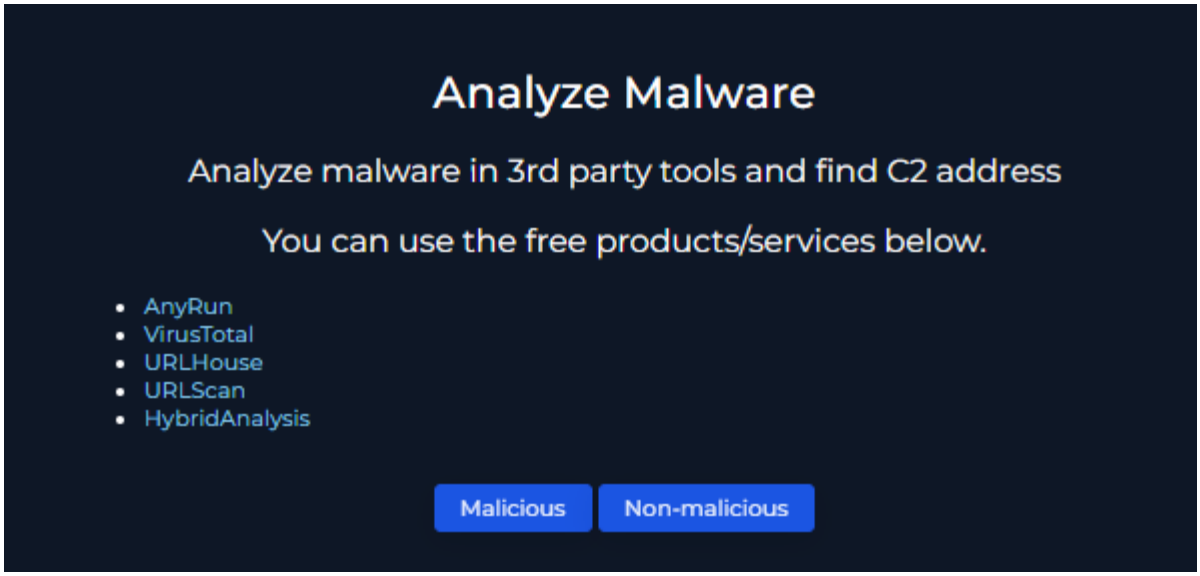
El indicador principal en este caso no coincide con las 3 opciones visibles.



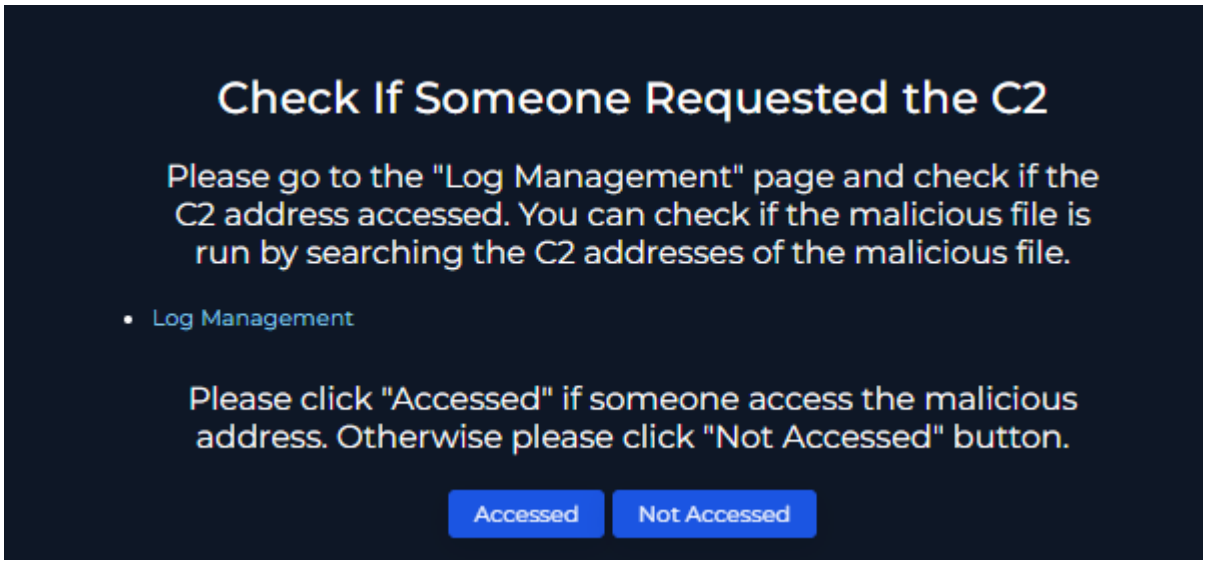
Como vimos se ejecutó de forma exitosa.



Ingresamos el resultado de nuestro análisis.



Aquí nos preguntan sobre la conexión al servidor del atacante malicioso.



Y agregamos los IOC encontrados

